

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 10

Domain II - Information Security Risk Management

30 Questions	48 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 48 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM3-028)

Which statement BEST describes target risk?

- A. The exposure that exists before any controls are considered
- B. The maximum loss the organization is financially able to absorb
- C. The desired level of risk after planned treatment has been implemented
- D. The exposure currently remaining after existing controls are considered

Question 2 (CISM3-029)

Which combination BEST represents internal and external context for an information security risk assessment?

- A. Only vulnerability scan results and software versions
- B. Only prior security incidents and current control tests
- C. Only laws, contracts, and threat intelligence reports
- D. Business objectives and capabilities together with obligations, market conditions, suppliers, and threats

Question 3 (CISM3-030)

Scenario: A shipping company normally tolerates four hours of tracking-system downtime. During a contractual holiday period, customer commitments reduce the approved tolerance to 30 minutes, but the last assessment used the normal-season limit.

What should the information security manager do?

- A. Reassess the holiday-period scenario using the 30-minute tolerance and related business impact
- B. Retain the four-hour limit because risk criteria should never vary over time
- C. Use the system administrator's preferred recovery time instead of business tolerance
- D. Wait for an outage to determine which tolerance is realistic

Question 4 (CISM3-031)

Scenario: A medical laboratory rates a label-printing server as noncritical because it stores no patient records. Process mapping shows that test samples cannot be matched, processed, or released when the server is unavailable.

Which conclusion is MOST appropriate?

- A. The server's availability criticality should reflect its dependency across the diagnostic process
- B. Only the printer hardware should be assessed because labels are physical
- C. The server remains noncritical because it stores no sensitive data
- D. The server is automatically the laboratory's most critical asset

Question 5 (CISM3-032)

Scenario: A charity moves donor analytics to a managed cloud database. The provider secures the underlying service, but the charity must configure access policies and encryption keys. The project assumes the provider performs all security tasks.

What is the PRIMARY assessment concern?

- A. Cloud services always create greater inherent risk than internal systems
- B. Unassigned customer responsibilities may leave access and key-management controls ineffective
- C. The provider should become the owner of donor-data risk
- D. The assessment should rely only on the provider's assurance report

Question 6 (CISM3-033)

Scenario: An engineering company uses a specialized software library maintained by one small supplier. Updates are automatically installed in design workstations, and neither update signatures nor supplier build controls have been reviewed.

Which scenario should receive the MOST attention?

- A. The supplier raises its annual subscription price
- B. Employees choose a competing library with a different user interface
- C. A compromised supplier update executes trusted malicious code across design workstations
- D. Design files become less valuable because the library is specialized

Question 7 (CISM3-034)

What is a PRIMARY limitation of multiplying ordinal likelihood and impact scores?

- A. The method can never support prioritization
- B. The numbers imply precision unsupported by the underlying categories.
- C. The method automatically measures risk appetite
- D. The method requires exact historical loss data

Question 8 (CISM3-035)

Scenario: A regional broadcaster values a transmission asset at \$1,200,000. A modeled cyber event would affect 15% of the asset's value. Management wants the single loss expectancy before considering event frequency.

What is the single loss expectancy?

- A. \$180,000
- B. \$80,000
- C. \$18,000
- D. \$1,020,000

Question 9 (CISM3-036)

Scenario: A manufacturer rated extortion risk as moderate six months ago. Recent industry intelligence shows sustained targeting of identical production equipment, and the company's controls have not changed. The potential operational impact also remains the same.

Which assessment update is MOST appropriate?

- A. Reduce inherent risk because current controls have remained stable
- B. Increase impact automatically because threat activity has increased
- C. Keep the rating unchanged until the company itself is attacked
- D. Reevaluate likelihood using the new threat evidence while retaining the supported impact analysis

Question 10 (CISM3-037)

Scenario: A property manager rates tenant-portal risk as low based on an expected authentication upgrade and a vendor statement that attacks are rare. Neither assumption is dated or linked to supporting evidence.

What should the information security manager do FIRST?

- A. Approve the low rating because two supporting assumptions exist
- B. Remove the scenario until the upgrade is completed
- C. Treat the vendor statement as independent validation
- D. Reassess current controls and document sources, assumptions, and the target state.

Question 11 (CISM3-038)

Scenario: A warehouse application has a known input-validation weakness. A protective filtering control is properly designed, but logs show it was disabled during the last three maintenance windows and not restored promptly.

How should the assessment characterize the findings?

- A. The weakness is a vulnerability; absent filtering is an operating control deficiency.
- B. Both findings are realized business impacts
- C. The maintenance windows are threats, and the weakness is residual risk
- D. The filtering control eliminates the vulnerability even while disabled

Question 12 (CISM3-039)

Scenario: A university has three medium-rated risks involving separate research systems. Each system relies on the same backup identity service, and a single failure would stop all three during a grant-submission deadline, producing a high aggregate impact.

What is the BEST assessment conclusion?

- A. Keep only the three local ratings because aggregation would duplicate risk
- B. Lower each rating because the identity service is a shared control
- C. Report and prioritize a distinct concentration scenario reflecting simultaneous impact
- D. Wait until the deadline passes before assessing concentration

Question 13 (CISM3-040)

Scenario: A food producer has limited event data. Simulation results show a wide range of plausible annual losses, but an executive asks for one guaranteed figure for the investment case.

What should the information security manager provide?

- A. The highest possible value presented as the expected loss
- B. A loss distribution or range with assumptions, confidence, and sensitivity information
- C. No estimate because limited data makes analysis impossible
- D. The average technical vulnerability score converted into currency

Question 14 (CISM3-041)

Scenario: A bank assumes that quarterly restore tests reduce backup-recovery risk to low. Evidence shows tests cover only small office files, while the assessed scenario concerns restoration of the core lending database.

What is the MOST appropriate conclusion?

- A. Inherent risk is low because some restore testing occurs
- B. Residual risk may be understated because the control evidence does not address the assessed scenario
- C. The control is effective because test frequency matters more than scope
- D. The database owner should accept the existing rating without further analysis

Question 15 (CISM3-042)

Scenario: A hospital board must choose whether to fund resilience for a medication-ordering service. The security team has produced 600 pages of technical findings but has not described patient-care impact, current residual risk, or response choices.

Which information should be presented FIRST?

- A. Every finding sorted by scanner severity
- B. The number of hours spent performing the assessment
- C. A request to fund all available controls without comparing their effects
- D. The material care-disruption scenario, exposure against appetite, key assumptions, and treatment options

Question 16 (CISM3-043)

Which action is an example of risk mitigation?

- A. Implementing a control that reduces scenario likelihood or impact.
- B. Purchasing coverage for specified financial consequences
- C. Formally retaining the exposure within approved authority
- D. Stopping the activity that creates the exposure

Question 17 (CISM3-044)

What is the PRIMARY responsibility of a control owner?

- A. Accept every business risk affected by the control
- B. Set enterprise risk appetite independently
- C. Operate or oversee the control and provide evidence of its performance
- D. Replace the business owner in all treatment decisions

Question 18 (CISM3-045)

Scenario: A bookstore's business owner decides to retain a low inventory-data risk within delegated tolerance because treatment would cost more than the expected impact. The decision is currently recorded only in meeting notes.

What should the information security manager do NEXT?

- A. Implement the rejected treatment because security should override the owner
- B. Record authorized acceptance with scope, rationale, assumptions, and review date.
- C. Remove the risk because acceptance means no exposure remains
- D. Ask the control operator to replace the business owner's decision

Question 19 (CISM3-046)

Scenario: A lending platform fails to meet a security requirement imposed by applicable law. A vendor offers insurance for related penalties, and the product owner proposes accepting the remaining exposure to preserve the launch date.

What is the BEST response?

- A. Engage legal and authorized leadership to implement a compliant treatment or change the launch decision
- B. Allow the product owner to accept noncompliance because revenue is at risk
- C. Launch and reassess only if a regulator asks for evidence
- D. Treat insurance as eliminating the legal requirement

Question 20 (CISM3-047)

Scenario: A hotel chain compares two controls for fraudulent loyalty redemptions. Each reduces residual risk within tolerance. Control X costs twice as much and delays legitimate redemptions; Control Y has no material customer impact and meets all obligations.

Which control should the information security manager recommend?

- A. Control X because a more expensive control is inherently stronger
- B. Both controls because every additional safeguard is required
- C. Control Y because it achieves acceptable risk with lower cost and business impact
- D. Neither control because risk cannot be reduced to zero

Question 21 (CISM3-048)

Scenario: A school district's student portal project records a high privacy risk, but the mitigation task has no budget, owner, or acceptance criterion. Development is almost complete and launch approval is next month.

What is the MOST effective corrective action?

- A. Assign the issue to the security backlog after launch
- B. Remove the risk from project reporting to protect the schedule
- C. Transfer risk ownership to the developers performing the work
- D. Assign an owner, fund treatment, and require acceptable residual risk at launch.

Question 22 (CISM3-049)

Scenario: A risk treatment plan states that three consecutive weeks above a fraud-loss threshold require reassessment. The metric exceeds the threshold for the third week, although total annual loss remains within budget.

Why should the reassessment be initiated?

- A. Every threshold breach proves that a control has completely failed
- B. The trigger identifies material change before annual totals conceal the trend.
- C. Budget performance automatically determines risk acceptance
- D. Reassessment transfers the risk to the monitoring team

Question 23 (CISM3-050)

Scenario: A payroll vendor cannot meet the buyer's recovery requirement. An alternate vendor can meet it, and contract negotiations are still open. The current vendor offers a service credit that would not cover business interruption.

What should the information security manager recommend?

- A. Compare the alternate vendor and other treatments, then obtain an authorized decision before signing
- B. Accept the service credit as complete transfer of operational risk
- C. Let procurement choose solely on price because recovery is technical
- D. Sign first and address recovery during the annual supplier review

Question 24 (CISM3-051)

Scenario: A rail operator cannot patch a signaling component during its certified service life. It proposes network segmentation and continuous command monitoring, but testing covers only office-network traffic and not the signaling protocol.

What should the information security manager conclude?

- A. The controls are sufficient because both are recognized security practices
- B. The patch exception should be permanent because certification prevents change
- C. Effectiveness is not demonstrated until testing covers the signaling scenario and expected control behavior
- D. The risk has been transferred to the monitoring provider

Question 25 (CISM3-052)

Scenario: A business owner accepted a mobile-device risk for six months on the condition that devices remain read-only. A change request would enable data editing before the acceptance expires.

What should occur before the change is approved?

- A. Reassess the changed scenario and obtain a new response decision from the authorized owner
- B. Keep the original acceptance because its calendar expiration has not passed
- C. Approve the change because editing is a business feature
- D. Ask the device supplier to inherit the acceptance

Question 26 (CISM3-053)

Scenario: A telecommunications firm relies on access recertification to keep privileged-access risk within tolerance. Completion has fallen for four quarters, the documented trigger has been breached, and corrective deadlines have repeatedly slipped.

What should the information security manager do NEXT?

- A. Lower the completion target to match current performance
- B. Report only the latest quarter because older trends are no longer relevant
- C. Transfer risk ownership to the recertification team
- D. Escalate the trend and current residual exposure to the risk owner for a revised treatment decision

Question 27 (CISM3-054)

Scenario: A publisher acquires a small digital platform. Due diligence assumed the platform would remain isolated for a year, but management now plans immediate connection to customer identity and payment services.

What is the MOST appropriate action?

- A. Rely on the due-diligence rating because the acquired platform itself is unchanged
- B. Reassess the new trust relationships, data flows, controls, and aggregate impact before connection
- C. Transfer the integration risk to the acquired company's former owner
- D. Connect first and monitor for incidents during the first month

Question 28 (CISM3-055)

Scenario: Seven departments hold valid local exceptions to multifactor authentication. Each is below its local threshold, but together the exceptions cover most finance administrators and exceed enterprise appetite.

What should the information security manager do?

- A. Keep reporting each exception separately because local approvals are valid
- B. Report the aggregated exposure and seek an enterprise-level treatment or acceptance decision
- C. Delete local records after creating one combined entry
- D. Wait until an exception expires before notifying leadership

Question 29 (CISM3-056)

Scenario: An energy trader must address an above-tolerance remote-access risk before a seasonal demand peak. One control can be deployed in two weeks and reaches tolerance with moderate user friction. A more convenient control cannot be ready for four months. Both meet obligations and cost about the same.

Which recommendation is BEST?

- A. Wait four months because convenience is the primary security objective
- B. Accept the risk informally until the preferred control is ready
- C. Deploy the timely control before the peak and review longer-term usability improvements afterward
- D. Deploy neither control because each has a business tradeoff

Question 30 (CISM3-057)

Scenario: A board committee receives a list of overdue control tasks but cannot determine why customer-data exposure has risen despite increased spending or which decisions require its attention.

Which reporting approach is MOST appropriate?

- A. Delay reporting until all overdue tasks are completed
- B. Add every technical ticket and remove summaries to provide maximum detail
- C. Report only spending because investment demonstrates risk reduction
- D. Relate material risk trends to appetite, treatment, exceptions, and required decisions.

Answer Key

Domain II - Information Security Risk Management

1 C	2 D	3 A	4 A	5 B
6 C	7 B	8 A	9 D	10 D
11 A	12 C	13 B	14 B	15 D
16 A	17 C	18 B	19 A	20 C
21 D	22 B	23 A	24 C	25 A
26 D	27 B	28 B	29 C	30 D

Detailed Explanations

Question 1 (CISM3-028)

Correct answer: C - The desired level of risk after planned treatment has been implemented

Target risk is the intended exposure after planned treatment is successfully implemented. Inherent risk exists before controls, risk capacity concerns the maximum exposure the organization can absorb, and residual risk reflects the current exposure after existing controls.

Question 2 (CISM3-029)

Correct answer: D - Business objectives and capabilities together with obligations, market conditions, suppliers, and threats

A sound context combines internal objectives, capabilities, processes, and constraints with external obligations, dependencies, market factors, and threats. Each other option supplies useful evidence but is too narrow to establish the full setting in which risk decisions are made.

Question 3 (CISM3-030)

Correct answer: A - Reassess the holiday-period scenario using the 30-minute tolerance and related business impact

The approved seasonal commitment changes the acceptable disruption and therefore the assessment criteria. The normal limit no longer represents the relevant objective, a technical preference cannot replace business tolerance, and waiting for a loss would leave the peak exposure unmanaged.

Question 4 (CISM3-031)

Correct answer: A - The server's availability criticality should reflect its dependency across the diagnostic process

Criticality depends on business-process consequences, not solely on stored data, and the server is an essential availability dependency. Assessing only hardware omits the supporting service, while identifying an important dependency does not prove it is the laboratory's single most critical asset.

Question 5 (CISM3-032)

Correct answer: B - Unassigned customer responsibilities may leave access and key-management controls ineffective

The mistaken responsibility assumption can leave required customer-side controls unowned or unconfigured. Cloud deployment does not automatically mean greater inherent risk, the charity retains accountability for donor data, and an assurance report cannot evaluate the charity's own configuration duties.

Question 6 (CISM3-033)

Correct answer: C - A compromised supplier update executes trusted malicious code across design workstations

Automatic trusted updates without signature or build assurance create a plausible path for supply-chain compromise at scale. Interface preference and price are business concerns but not the central information security scenario, while specialization does not reduce the value of design files.

Question 7 (CISM3-034)

Correct answer: B - The numbers imply precision unsupported by the underlying categories.

Ordinal categories do not necessarily have equal intervals, so multiplying them can create a misleading appearance of precision. Such models can still support prioritization when definitions are clear, they do not require exact loss history, and appetite must be established separately.

Question 8 (CISM3-035)

Correct answer: A - \$180,000

Single loss expectancy equals asset value multiplied by exposure factor: \$1,200,000 multiplied by 15% equals \$180,000. The calculation does not use annual frequency; that would be needed later to estimate annualized loss expectancy.

Question 9 (CISM3-036)

Correct answer: D - Reevaluate likelihood using the new threat evidence while retaining the supported impact analysis

New targeting evidence directly affects the likelihood estimate, while unchanged business consequences may leave impact stable. Greater threat activity does not automatically increase impact, waiting for an attack ignores relevant evidence, and stable controls do not reduce inherent risk.

Question 10 (CISM3-037)

Correct answer: D - Reassess current controls and document sources, assumptions, and the target state.

Current residual risk must use controls operating now, and every material assumption should be traceable and time-bound. An unimplemented upgrade cannot support today's residual rating, a vendor statement is not independent evidence, and removing the scenario would hide current exposure.

Question 11 (CISM3-038)

Correct answer: A - The weakness is a vulnerability; absent filtering is an operating control deficiency.

The input-validation weakness is an exploitable condition, while failure to restore a designed control is an operating deficiency. Neither finding alone is a realized impact, a maintenance period is not the threat actor or event, and a disabled control cannot reduce exposure as intended.

Question 12 (CISM3-039)

Correct answer: C - Report and prioritize a distinct concentration scenario reflecting simultaneous impact

The shared dependency creates a correlated scenario whose combined deadline impact is not visible in separate local ratings. Reporting it does not require deleting useful local entries, shared infrastructure does not automatically lower risk, and waiting would ignore a time-sensitive exposure.

Question 13 (CISM3-040)

Correct answer: B - A loss distribution or range with assumptions, confidence, and sensitivity information

A range or distribution with assumptions and sensitivity conveys the model's decision value and limitations. A worst case is not the expected value, technical scores cannot be directly converted into financial loss, and limited data can still support transparent scenario analysis.

Question 14 (CISM3-041)

Correct answer: B - Residual risk may be understated because the control evidence does not address the assessed scenario

Control evidence must match the scenario and asset in scope; office-file testing does not demonstrate recoverability of the lending database. Testing does not change inherent risk, frequency cannot compensate for irrelevant scope, and acceptance should follow a corrected assessment rather than preserve an unsupported rating.

Question 15 (CISM3-042)

Correct answer: D - The material care-disruption scenario, exposure against appetite, key assumptions, and treatment options

The board needs a concise business scenario, its position against appetite, supporting assumptions, and viable treatments to make the funding decision. Technical detail and assessment effort do not establish business importance, and funding every control ignores proportionality and expected risk reduction.

Question 16 (CISM3-043)

Correct answer: A - Implementing a control that reduces scenario likelihood or impact.

Mitigation uses controls or process changes to reduce likelihood or impact. Stopping the activity is avoidance, insurance transfers or shares defined financial consequences, and formally retaining exposure is acceptance.

Question 17 (CISM3-044)

Correct answer: C - Operate or oversee the control and provide evidence of its performance

A control owner is accountable for the assigned control's operation, maintenance, and performance evidence. This role does not automatically include business-risk acceptance, enterprise appetite setting, or replacement of the accountable risk owner.

Question 18 (CISM3-045)

Correct answer: B - Record authorized acceptance with scope, rationale, assumptions, and review date.

Formal recording makes the authorized decision traceable and defines what was retained, why, under which assumptions, and until when. Security should not override a valid business decision, acceptance does not eliminate exposure, and the control operator does not replace the risk owner.

Question 19 (CISM3-046)

Correct answer: A - Engage legal and authorized leadership to implement a compliant treatment or change the launch decision

Insurance does not remove a mandatory legal duty, and a product owner cannot accept noncompliance when policy and law do not permit it. Legal and accountable leadership must choose a compliant treatment or alter the launch; waiting for regulatory attention is not a valid response.

Question 20 (CISM3-047)

Correct answer: C - Control Y because it achieves acceptable risk with lower cost and business impact

Control Y reaches the required risk level with better cost and customer outcomes. Price does not prove effectiveness, adding both is not justified when either is sufficient, and risk need not reach zero for a treatment to be appropriate.

Question 21 (CISM3-048)

Correct answer: D - Assign an owner, fund treatment, and require acceptable residual risk at launch.

Connecting ownership, funding, treatment evidence, and the launch gate makes the risk decision enforceable within project governance. A later backlog is too late, developers do not automatically own business consequences, and hiding the risk prevents an informed launch decision.

Question 22 (CISM3-049)

Correct answer: B - The trigger identifies material change before annual totals conceal the trend.

The predefined trigger provides an early signal that exposure may be changing and requires review even if the annual budget is not yet exceeded. A breach does not prove total control failure, budget status is not risk acceptance, and monitoring does not transfer ownership.

Question 23 (CISM3-050)

Correct answer: A - Compare the alternate vendor and other treatments, then obtain an authorized decision before signing

Because contractual leverage and an alternative remain available, the organization should compare treatments and resolve residual risk before commitment. A service credit transfers only limited financial consequences, later review loses leverage, and recovery supports business continuity rather than being only a technical concern.

Question 24 (CISM3-051)

Correct answer: C - Effectiveness is not demonstrated until testing covers the signaling scenario and expected control behavior

Controls must be validated against the specific asset, protocol, threat path, and expected outcome. Familiar control names do not prove coverage, certification does not justify indefinite exception, and outsourced monitoring does not transfer the operator's business accountability.

Question 25 (CISM3-052)

Correct answer: A - Reassess the changed scenario and obtain a new response decision from the authorized owner

The proposed capability violates a material condition of the acceptance, so the exposure must be reassessed and decided again before approval. The remaining time does not preserve an invalid assumption, business value alone does not authorize the risk, and the supplier cannot inherit the owner's accountability.

Question 26 (CISM3-053)

Correct answer: D - Escalate the trend and current residual exposure to the risk owner for a revised treatment decision

A sustained decline, breached trigger, and missed corrective actions show that the existing response may no longer maintain acceptable risk. The owner needs the trend and current exposure to decide on treatment; lowering targets, omitting history, or transferring ownership would conceal rather than resolve the issue.

Question 27 (CISM3-054)

Correct answer: B - Reassess the new trust relationships, data flows, controls, and aggregate impact before connection

Immediate integration invalidates the isolation assumption and introduces new trust, data, and impact paths that require assessment before exposure changes. The prior rating no longer fits, postconnection monitoring is too late for the decision, and the former owner cannot accept the publisher's integration risk.

Question 28 (CISM3-055)

Correct answer: B - Report the aggregated exposure and seek an enterprise-level treatment or acceptance decision

Valid local decisions can still create an unacceptable aggregate exposure, requiring enterprise-level visibility and authority. Local records remain useful for ownership, while delaying escalation or reporting only separate entries would hide the concentration risk.

Question 29 (CISM3-056)

Correct answer: C - Deploy the timely control before the peak and review longer-term usability improvements afterward

The timely control reduces exposure within tolerance before the period of greatest risk while preserving an opportunity to improve usability later. Waiting leaves a known exposure above tolerance, informal acceptance lacks authority, and manageable tradeoffs do not justify rejecting both viable responses.

Question 30 (CISM3-057)

Correct answer: D - Relate material risk trends to appetite, treatment, exceptions, and required decisions.

Executive reporting should connect exposure and trends to appetite, explain whether treatments work, identify exceptions, and make decision needs explicit. More ticket detail does not supply business meaning, spending alone does not prove reduced risk, and delaying reporting prevents timely oversight.